# DEFENDER SUMMIT 2026

# 침해평가 INSIGHT

나루씨큐리티 위협대응센터

박영준 팀장 & 이재광 센터장

# 목차

01
Intro
개요

02
ZeroTrust
제로트러스트

03
Compromise Assessment
침해평가

01

# Intro

01. Intro

# 최근 발생된 사이버 보안 사고의 동향

왜 이런 장기간 통신을 눈치를 채지 못할까?

**4 년**

장기간 백도어

**1 년**

장기간 백도어

**3년**

무단 자료 열람

**8개월**

개인정보 유출

01. Intro

# 보안의 새로운 전략 제로트러스트

모든 것을 검증하는 새로운 보안 전략

# Zero Trust

**모든 통신의 신뢰성을 검증한다.**

01. Intro-

# 보안에 적용하기 어려운 제로트러스트

우리는 왜 제로트러스트에 거부감이 있을까?

ZeroTrust

| | | |
|---|---|---|
| 01 부족한 분석 시간 | 33,422,071<br>나루씨큐리티에서 한달동안 발생된 세션의 수 | 13,158,654<br>나루씨큐리티에서 한달동안 송/수신된 파일의 수 |
| 02 SW의 다양한 변화 | SW 업데이트<br>업데이트로 인한 통신의 패턴 변화 | 신규 서비스<br>보안 담당도 모르는 내부망의 신규 서비스들 |
| 03 불필요한 감정의 소모 | 보안 SW 설치<br>SW 설치에 대한 거부감 | 확인 및 협조 요청<br>징계 우려, 업무 추가 등의 부서 간 트러블 |

# ZeroTrust를 어떻게 적용해야 하는가?

02

# Zero Trust

02. ZeroTrust

# ZeroTrust를 어떻게 적용할 것인가?

ZeroTrust는 현장에 바로 적용할 수 있는가?

# ZeroTrust

모든 통신의 신뢰성을 검증한다.

하지만, 모든 통신을 확인하는 것은 어렵다.

02. ZeroTrust

# ZeroTrust를 적용하기 힘든 이유

네트워크의 보안 대응은 대부분 초기 침투에 집중 되어있다.

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성

| Initial Access (3 techniques) | Execution (2 techniques) | Persistence (10 techniques) | Privilege Escalation (4 techniques) | Defense Evasion (11 techniques) | Credential Access (6 techniques) | Discovery (11 techniques) | Lateral Movement (1 techniques) | Collection (4 techniques) | Command and Control (7 techniques) | Exfiltration (2 techniques) | Impact (4 techniques) |
|---|---|---|---|---|---|---|---|---|---|---|---|
| Exploit Public-Facing Application | Command and Scripting Interpreter (3) | Account Manipulation (1) | Account Manipulation (1) | Direct Volume Access | Adversary-in-the-Middle (1) | File and Directory Discovery | Software Deployment Tools | Adversary-in-the-Middle (1) | Application Layer Protocol (5) | Automated Exfiltration (1) | Disk Wipe (2) |
| Valid Accounts (2) | Software Deployment Tools | Boot or Logon Autostart Execution | Boot or Logon Autostart Execution | Impair Defenses (4) | Brute Force (4) | Network Service Discovery | | Data from Configuration Repository (2) | Encrypted Channel (2) | Exfiltration Over Alternative Protocol (1) | Firmware Corruption |
| Wi-Fi Networks | | Boot or Logon Initialization Scripts (1) | Boot or Logon Initialization Scripts (1) | Indicator Removal (3) | Input Capture (1) | Network Sniffing | | Data from Local System | Hide Infrastructure | | Inhibit System Recovery |
| | | Create Account (1) | Valid Accounts (2) | Modify Authentication Process (1) | Modify Authentication Process (1) | Password Policy Discovery | | Input Capture (1) | Ingress Tool Transfer | | System Shutdown/Reboot |
| | | Modify Authentication Process (1) | | Modify System Image (2) | Network Sniffing | Process Discovery | | | Non-Application Layer Protocol | | |
| | | Power Settings | | Network Boundary Bridging (1) | Unsecured Credentials (1) | Remote System Discovery | | | Proxy (3) | | |
| | | Pre-OS Boot (3) | | Obfuscated Files or Information (1) | | System Information Discovery | | | Traffic Signaling (1) | | |
| | | Server Software Component (1) | | Pre-OS Boot (3) | | | | | | | |
| | | Traffic | | | | | | | | | |

02. ZeroTrust

# 왜 ZeroTrust를 적용하려 하는가?

ZeroTrust의 개념이 왜 나왔는지 생각해보자

아동 납치 예방관련 "엠버 경고"에 대한 공익광고

02. ZeroTrust

# 왜 ZeroTrust를 적용하려 하는가?

악성 이력이 없는 통신은 정상 통신과 구분하기 어렵다

방화벽(또는 NDR) 로그

02. ZeroTrust

# 보안의 방어 포인트

우리는 언제든지 내부가 감염이 될 수 있다는 것을 전제로 보안을 수행해야 한다.

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성

02. ZeroTrust

# 제로트러스트를 어떻게 적용해야 하는가?

공격자가 목표를 달성하기 이전 "모든 통신을 검증했다"라는 결론을 내기 위한 과정이 필요하다.

# ZeroTrust

## 모든 통신의 신뢰성을 검증한다

신경 써야 하는 부분

# 통신의 검증은 어떤식으로 진행해야 하는가?

03

# Compromise Assessment

03. Compromise Assessment

# 나루씨큐리티는 어떤식으로 제로트러스를 적용하고 있는가?

기업에 제로트러스트 기반 서비스를 제공하기 위한 고민을 했습니다.

01

## 내부망 변화 관리 모델링

IP와 통신의 변화 관리를 통해
우선적으로 봐야 하는 통신을 식별

02

## 고객과의 지속적인 소통

명확한 기준과 데이터를 통해
확인이 필요한 IP와 통신에 대한
비정상 여부를 상호 검증

03

## 지속적인 분석 환경

위협 분석가들이
분석에만 집중할 수 있는 환경 구성

**기업 내부망에 제로트러스트의 적용을 위한 3가지 장치**

03. Compromise Assessment

나루씨큐리티에서는
제로트러스트와 침해평가를 융합한 서비스를 제공

# ZeroTiCA

## ZeroTrust + CA(Compromise Assessment)

03. Compromise Assessment

# 내부망의 변화를 관리할 수 있는 모델링

분석가가 집중적으로 분석할 수 있는 여러 단계의 필터링을 구축

**03. 화이트 리스트(2차)**
기업 또는 망의 환경에 필요한
이벤트 제외

**01. 화이트 리스트(1차)**
신뢰성 있는 SW의 통신

**04. 변화 관리**
분석 우선 순위가 높은 통신을 식별

**02. 이벤트 식별**
공격 행위에 대한 통신 식별 (포괄적)

03. Compromise Assessment

# 일 단위의 데이터 분석과 이벤트 간 연계 분석

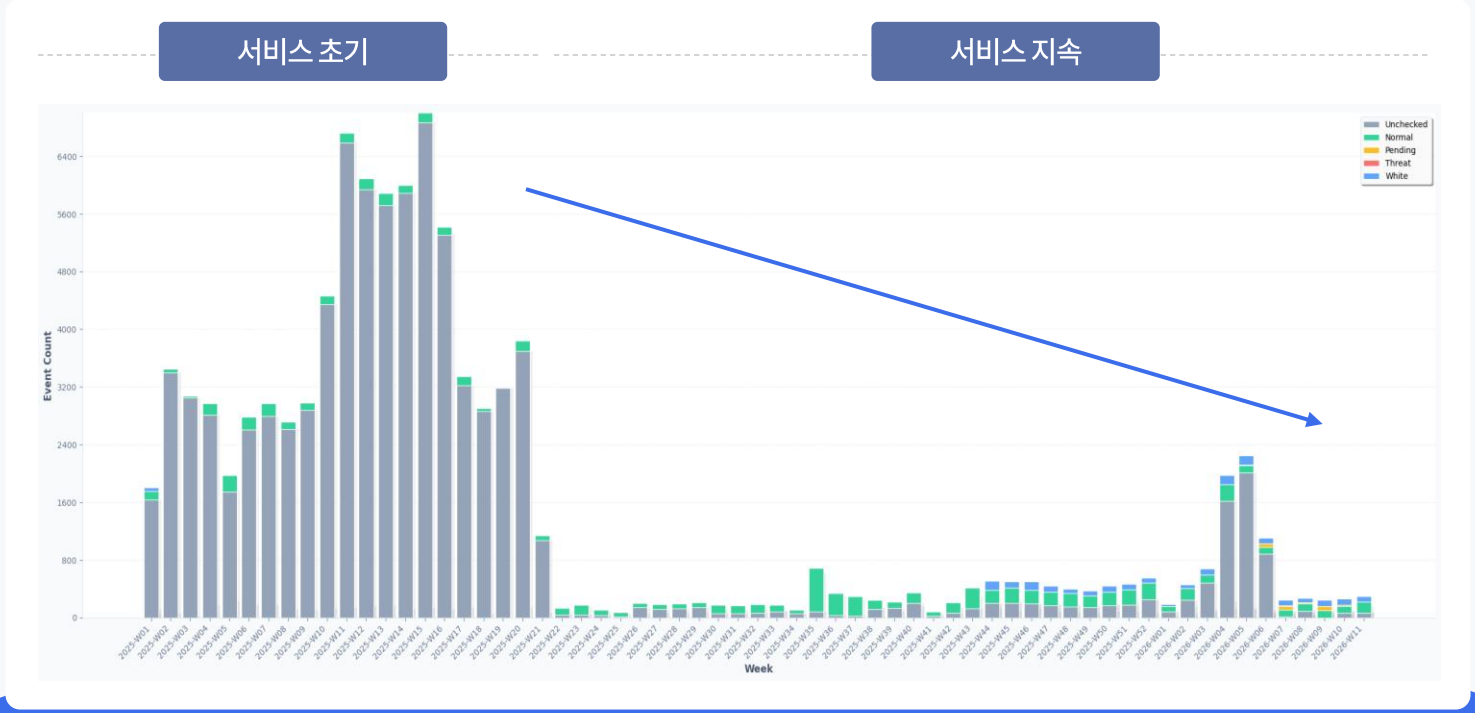
단일 세션 분석, 세션 통합 분석 등 여러가지 방법을 통한 데이터 분석 수행

| 01 | 02 | 03 |
|---|---|---|
| 인바운드<br>외부에 노출된 자산 | 아웃바운드<br>악성 C2, 백도어 통신 | 내부 이동<br>환경 조사, 내부망 장악 |
| 웹 셸 통신 | ○ 기계적 통신 | ○ 스캔 통신 |
| 비정상 User-Agent 식별 | C2 통신 | ○ 비정상 연결 실패 비율 식별 |
| 응답 실패율 이상 | 장시간 통신 | 비정상 L7 프로토콜 동작 |
| 비정상 URI | 비정상 데이터 이동 | 기계적 통신 |
| ⋮ | ⋮ | ⋮ |

03. Compromise Assessment

# 보안은 마라톤이다

끊임없는 검증과 확인을 수행하여, 내부망의 통신을 정리해야 한다.



# 03-1. CASE #1

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성

**Long Session Log**

| datetime | src_ip | src port | dst_ip | dst port | proto | service | duration |
|---|---|---|---|---|---|---|---|
| 2026-02-03 19:16:37 | [redacted] | 35460 | NL 51.15. [redacted] Scalew | 8000 | tcp | ssh | 4시간 41분 |
| 2026-02-03 19:16:37 | [redacted] | 35460 | NL 51.15. [redacted] Scalew | 8000 | tcp | ssh | 28시간 41분 |

그래프 보기

| src_pkts | src_bytes | dst_pkts | dst_bytes | group |
|---|---|---|---|---|
| 30,067 | 33.0 MB | 18,375 | 1.9 MB | Scaleway S.a.s. |
| 70,986 | 74.1 MB | 40,485 | 5.6 MB | Scaleway S.a.s. |

03-1. CASE #1

# 이러한 통신이 발견되었을 때 보안 분석가의 고뇌

선제적으로 확인을 요청할 때의 상황

**왜 문제가 되는 거죠?**

사고 이후에 후속 조치를 수행할 때의 상황

**왜 그때 확인하지 않은 거죠?**

WHY? 문제로 도출하기 위한 근거가 부족하다 / 결과를 기반으로 발생한 원인을 찾는 것은 쉽다

공격자의 행동 변화를 관측하여, 담당자를 설득할 수 있는 근거를 확보해야 한다.

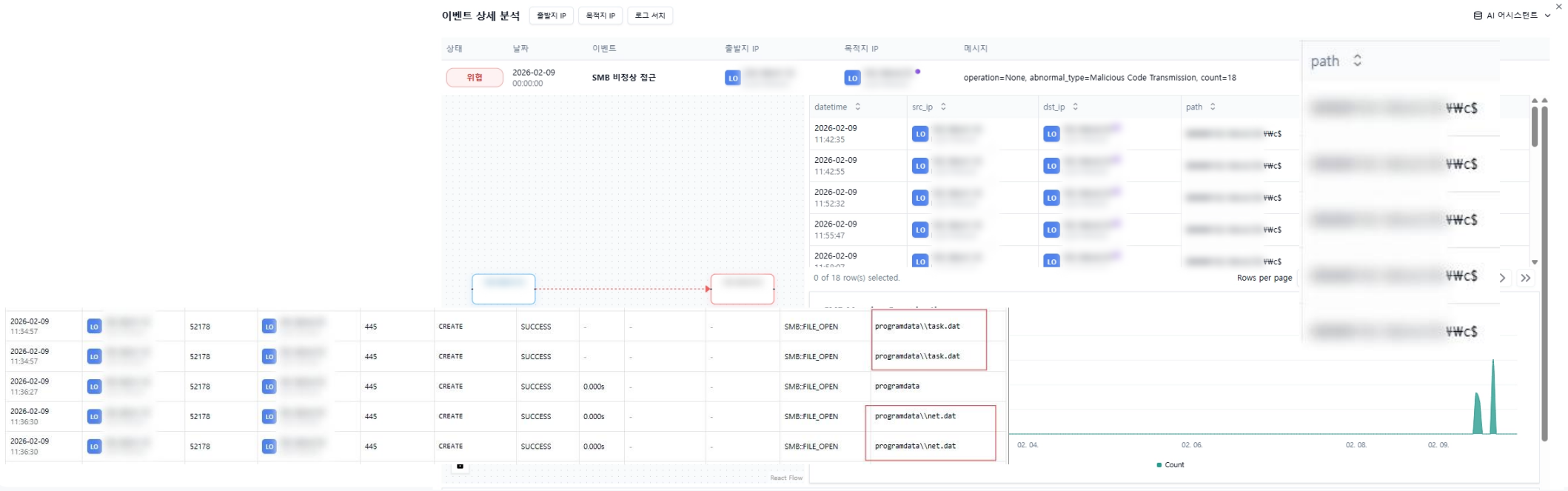
# 03-1. CASE #1

01 초기 침투

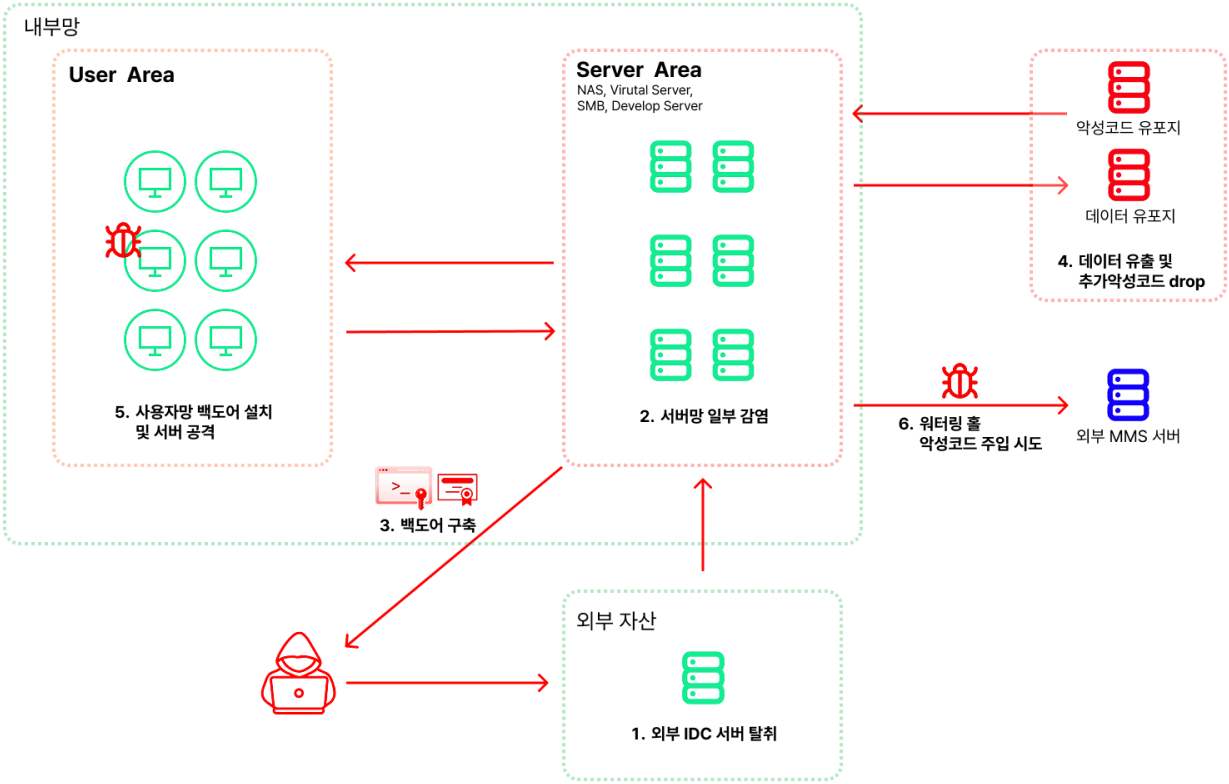
02 내부 정보 수집

03 내부망 장악

04 목표 달성



# 03-2. CASE #2


내부망
User Area
5. 사용자망 백도어 설치
및 서버 공격
Server Area
NAS, Virutal Server,
SMB, Develop Server
2. 서버망 일부 감염
악성코드 유포지
데이터 유포지
4. 데이터 유출 및
추가악성코드 drop
6. 워터링 홀
악성코드 주입 시도
외부 MMS 서버
3. 백도어 구축
외부 자산
1. 외부 IDC 서버 탈취

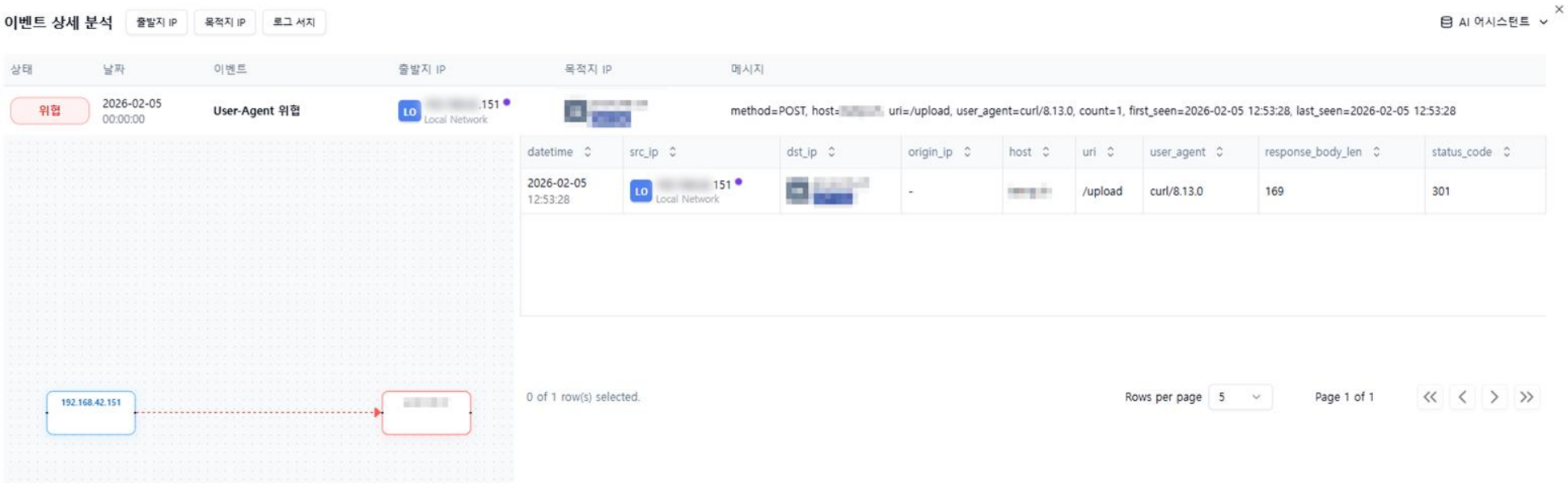
# 03-2. CASE #2

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성



# 03-2. CASE #2

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성

02

고객과의 지속적인 소통

명확한 기준과 데이터를 통해
확인이 필요한 IP와 통신에 대한
비정상 여부를 상호 검증

# 03-2. CASE #2

01 초기 침투

02 내부 정보 수집

03 내부망 장악

04 목표 달성

```
Source IP
  횟수 IP
12990 [redacted] 254
    289 [redacted].30
    252 [redacted].40
    110 [redacted].41
     63 [redacted].22        //backup-nas:5357
      8 [redacted] 75
      2 [redacted] 85 //감염

Destination IP
12368 [redacted].49
  670 [redacted] 74
  588 [redacted] 160
   71 [redacted] 42
    5 [redacted] 185
    4 [redacted] 40
    2 [redacted] 19
    2 [redacted] 84
    2 [redacted] 31
    2 [redacted] 212
```

**SSH Log**

| datetime | src_ip | src_port | dst_ip | dst_port | version | auth_success |
|---|---|---|---|---|---|---|
| 2026-01-30 13:19:10 | LO [redacted] 85 | 34070 | LO [redacted] 31 | 22 | SSH v2 | Success |
| 2026-01-30 13:19:17 | LO [redacted] 85 | 34082 | LO [redacted] 31 | 22 | SSH v2 | Success |
| 2026-01-30 15:47:55 | LO [redacted] 85 | 57772 | LO [redacted] 31 | 22 | SSH v2 | Success |
| 2026-01-30 15:48:21 | LO [redacted] 85 | 45186 | LO [redacted] 31 | 22 | SSH v2 | Success |
| 2026-01-30 15:48:26 | LO [redacted] 85 | 45188 | LO [redacted] 31 | 22 | SSH v2 | Success |
| 2026-02-03 21:02:11 | LO [redacted] 85 | 42322 | LO [redacted] 32 | 22 | SSH v2 | Success |

118시간 장기 지속 연결

끊임없는 확인과 변화 관리가 필요하다